

PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	Users can create member profiles internally or by connecting external accounts There is a lot of back-end processes for high client experience. The app will process transactions. The app should be in compliance with PCI-DSS.
II. Define the technical scope	APIs facilitate the exchange of data between customers, partners, and employees, so they should be prioritized. They handle a lot of sensitive data while they connect various users and systems together. The attack surface is huge because of the APIs. Also adequately implemented SQL should be considered, because the input field might be a direct vector of the attack.
III. Decompose application	Data is going from user to the search field (input field). After that the query is made to database. Database brings all asked information to the server and present it to the client
IV. Threat analysis	Internal threats: angry employee, who might decide to steal users information or disrupt the order of the whole database External threats: Malicious actor (like independent hacker or any competitor of the company), who might infect the system with the SQL injection attack and steal client's PII or take other type of advantage from database.

	Session hijacking also should be considered.
V. Vulnerability analysis	The application might be vulnerable for SQL injection attacks because of the SQL Another vulnerability might be malicious code from third party's API.
VI. Attack modeling	Threat actor's main target is user information. Application is vulnerable to SQL injections and Session hijackings. Threat actor might exploit Lack of prepared statements or Weak login credentials.
VII. Risk analysis and impact	Security controls, which are recommended to implement because of the gathered information: 1. Prepared Statements 2. Input Validation 3. Intrusion Prevention System (IPS) 4. Strong Password Policies 5. Principle of least privilege
